

Project 3: Phishing Awareness Analysis

ANALYST	ORGANIZATION	BATCH
SOPHIA NICHOLAS-IKE	DecodeLabs	2026

1. EXECUTIVE SUMMARY & CORE OBJECTIVES

Strategic Purpose: As part of building an organizational "Human Firewall," this project analyzes deceptive communications, identifies technical disguises, and establishes standard operating procedure (SOP) frameworks to triage inbound communication threats effectively.

Key Deliverables Completed

- Threat Identification & Red Flag Audit:** Comprehensive analysis of visual cues, header manipulations, and deceptive tactics across channels.
- Technical Dissecting Checklist:** Standardized guidelines for parsing sender domains, header records, and lookalike link structures.
- Phishing Triage SOP & Decision Tree:** A practical triage routing framework directing actions to **SAFE -> CLOSE**, **SUSPICIOUS -> WARN USER**, or **MALICIOUS -> BLOCK DOMAIN & ESCALATE**.

2. TECHNICAL RED FLAG ANALYSIS & THREAT TAXONOMY

A. Technical & Domain Red Flags

Sender & Header Anomalies Sender-Domain Mismatch: Conflicting display names vs. underlying routing domains (e.g., Display: <i>Microsoft Support</i>, Actual: <code>support@logins-updates.com</code>). True Domain Spoofing: Absence or misconfiguration of SPF, DKIM, and DMARC authentication protocols allowing unauthorized domain usage.	Domain Manipulation Tricks Nested Subdomains: Fake subdomains ahead of a malicious root (e.g., <code>decode labs . tech . login - update . com</code>, where true root is <code>login - update . com</code>). Lookalike Domains: Typosquatting (<code>amazon . com</code>), Combosquatting (<code>company - secure - login . com</code>), and IDN Homoglyphs.
Advanced Vectors & Exploits Dangerous Attachments: High-risk extensions (<code>.iso</code>, <code>.js</code>, <code>.scr</code>) or HTML smuggling payloads designed to bypass gateway security filters. Browser-in-the-Browser (BitB): Simulated single sign-on (SSO) pop-up windows inside an HTML frame that cannot be moved outside browser viewports.	

■ 2. TECHNICAL RED FLAG ANALYSIS (CONTINUED)

B. Psychological & Contextual Triggers

Attackers intentionally manipulate human cognitive triggers to bypass rational evaluation and security protocols:

- **Urgency:** Time-limited demands (e.g., "Account locked in 30 minutes", "Password expires in 24 hrs") designed to prompt immediate compliance.
- **Authority Impersonation:** Faking C-suite executives, IT support, or legal representatives demanding confidential transfers or actions.
- **Urgent Bypass Demands:** Direct instructions urging strict confidentiality or requesting explicit departure from standard procurement/security controls.
- **Curiosity & Fear:** Unsolicited policy violation warnings, unexpected performance reviews, or unearned financial rewards.

C. Modern & Multi-Channel Vectors

TOAD & Quishing

- **Callback Phishing (TOAD):** Lure emails containing no malicious links, only support phone numbers urging targets to call fake centers.
- **Quishing (QR Codes):** Malicious QR codes in PDFs/posters directing desktop users to unmanaged, unprotected mobile browsers.

Deepfakes & MFA Attacks

- **Deepfake Audio/Video:** Synthetic voice calls or video clips in live meetings followed by fraudulent email confirmation requests.
- **MFA Fatigue (Prompt Bombing):** Flooding targets with push notifications until they tap "Approve" to stop the disturbance.

■ 3. STANDARD OPERATING PROCEDURE (SOP): NON-EXPERT TRIAGE

When inspecting any suspicious inbound email or message, personnel must apply the **Pause, Verify, Report** model:

Phase 1: Header & Domain Verification

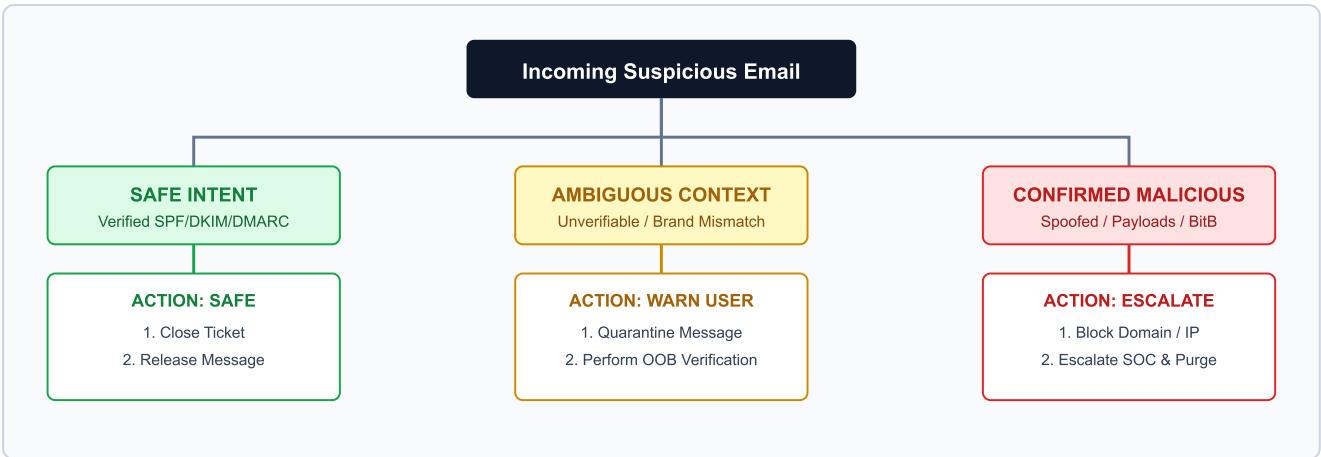
1. **Inspect Display Name vs. From Address:** Expand header details. Verify if the display name matches the exact originating email domain.
2. **Read URLs Right-to-Left:** Identify the true root domain immediately preceding the TLD (`.com` , `.tech`). Discard pre-pended subdomains.
3. **Check Character Substitutions:** Look closely for homoglyphs or numerical replacements (`0` for `o` , `1` for `l`).
4. **Evaluate Reply-To Lines:** Confirm the `Reply-To` header aligns with the sender's verified corporate domain.

Phase 2: Content & Context Verification

1. **Verify Out-of-Band (OOB):** If funds, credentials, or policy changes are requested, verify via a known phone number or internal chat. Never rely on phone numbers inside the message.
2. **Check Attachments:** Do not download or execute attachments with unusual extensions (`.iso` , `.js` , `.scr` , `.exe`).
3. **Analyze Action Urgency:** Flag messages demanding immediate action, secrecy, or bypassing standard organizational procedures.

■ 4. THREAT TRIAGE DECISION TREE

Operational logic flow for routing incoming suspicious communications across security triage tiers:



Action Matrix Overview

Category	Technical Indicators	Mandatory Action
SAFE	Verified SPF/DKIM/DMARC alignment, established routine business contacts, no psychological red flags.	Close: Resolve ticket and release email from quarantine filter.
SUSPICIOUS	External domain presenting internal context, unverified sender credentials, non-standard link formats.	Warn User: Maintain quarantine hold, issue security alert, run out-of-band check.
MALICIOUS	Domain spoofing, typosquatting/homoglyph URLs, execution payloads (.iso / .js), TOAD scams, BitB frames.	Block & Escalate: Block domain at firewall/gateway, trigger Incident Response, purge inbox copies.

■ 5. SUMMARY & DEFENSIVE IMPACT

By implementing these technical parsing checklists and structured decision workflows, DecodeLabs significantly enhances its "Human Firewall." Systematically auditing header markers, URL topologies, and psychological pressure tactics bridges the gap between end-user detection and SOC incident response.